PLANO DE SEGURANÇA DA INFORMAÇÃO

Instituição de Ensino (IE)
Documento-base para proteção de dados, sistemas, equipamentos e continuidade

Escopo considerado
Aproximadamente 2.500 alunos • Professores • Equipe administrativa
Data center local • Servidor de arquivos • Site hospedado • Aplicativo
3 laboratórios de informática • Parque de desktops e notebooks

Versão 1.0 • 03 de novembro de 2026

Elaborado a partir das informações registradas na lousa. Deve ser validado pela direção e pela equipe de TI antes de ser adotado como política oficial.

Controle do documento

Campo	Descrição
Instituição	IE – nome oficial a preencher
Responsável	Coordenação de TI ou responsável formalmente designado
Aprovação	Direção da instituição
Versão	1.0 – 03/11/2026
Revisão	Anual e após incidente grave ou mudança relevante
Classificação	Uso interno

Premissas e limites

A lousa informa cerca de 2.500 alunos, professores, funcionários administrativos, data center on-premises, servidor de arquivos, site com hospedagem contratada, aplicativo, três laboratórios com aproximadamente 30 máquinas cada e parque de desktops/notebooks. Portanto, considera-se uma estimativa de 90 computadores nos laboratórios, além dos demais equipamentos. A quantidade total de dispositivos, servidores, links, sistemas, fornecedores e dados ainda precisa ser inventariada.

Atenção: este documento apresenta controles recomendados, não confirma que eles já existam. A equipe deve verificar o cenário real, registrar evidências e priorizar as ações conforme risco e orçamento.

Sumário executivo

O objetivo é reduzir a probabilidade e o impacto de incidentes que interrompam aulas, comprometam dados pessoais, indisponibilizem sistemas acadêmicos ou causem perda de arquivos. A estratégia combina prevenção, detecção, resposta e recuperação. As prioridades são conhecer os ativos, controlar acessos, proteger o data center e os endpoints, manter backups testados e preparar a instituição para responder a incidentes.

Prioridade	Diretriz	Resultado esperado
Crítica	Inventário, acessos privilegiados e backups	Reduzir perda de dados e invasão de contas críticas
Alta	Segmentação de rede, proteção dos endpoints e atualizações	Conter malware e acessos indevidos
Média	Treinamento, processos e gestão de fornecedores	Reduzir falhas humanas e riscos de terceiros
Contínua	Testes de recuperação e revisão de riscos	Manter a continuidade

1. Objetivos

- Proteger confidencialidade, integridade e disponibilidade das informações acadêmicas, administrativas e institucionais.
- Preservar dados de alunos, responsáveis, professores, colaboradores e fornecedores.
- Manter serviços essenciais disponíveis: sistemas acadêmicos, arquivos, site, aplicativo e conectividade.
- Definir responsabilidades, regras de acesso, backups, monitoramento e resposta a incidentes.
- Atender às obrigações legais aplicáveis, especialmente à Lei Geral de Proteção de Dados Pessoais (LGPD).

2. Escopo

Aplica-se a alunos, colaboradores, professores, prestadores de serviço e fornecedores que acessem recursos tecnológicos da IE, abrangendo:

- Data center local, servidores, armazenamento e servidor de arquivos.
- Rede cabeada e Wi-Fi, roteadores, switches, firewall, links de internet e pontos de acesso.
- Site institucional hospedado por empresa contratada, domínio, painel, banco de dados e contas administrativas.
- Aplicativo institucional, serviços de nuvem, integrações e contas de publicação.
- Três laboratórios, estimados em 30 computadores cada (aproximadamente 90 máquinas).

- Desktops e notebooks de professores, administração e demais setores.
- Sistemas acadêmicos, financeiros, administrativos, e-mail, armazenamento e impressão, após confirmação do inventário.

3. Inventário e classificação dos ativos

A IE deve manter inventário centralizado. Cada ativo terá identificador, responsável, localização, finalidade, sistema operacional/versão, criticidade, fornecedor, garantia e situação de atualização.

Ativo	Quantidade conhecida	Ação de inventário
Alunos	Aprox. 2.500	Mapear sistemas de cadastro, matrícula, notas, frequência e contatos.
Professores/administrativos	Não informada	Mapear contas, permissões, dispositivos e sistemas.
Data center	1 ambiente mencionado	Listar servidores, armazenamento, UPS, climatização, rede e acessos físicos.
Servidor de arquivos	1 serviço mencionado	Mapear pastas, responsáveis, permissões e dados armazenados.
Site	Hospedagem contratada	Registrar domínio, provedor, painel, código/CMS, banco e backups.
Aplicativo	Existência mencionada	Identificar plataforma, fornecedor, dados, APIs e contas de publicação.
Laboratórios	3 × cerca de 30	Etiquetar cerca de 90 máquinas e documentar imagem padrão e softwares.
Desktops/notebooks	Não informada	Registrar equipamentos por setor, usuário e localização.

Classificação da informação

Classe	Exemplos	Tratamento mínimo
Pública	Conteúdo aprovado para o site	Aprovação antes de publicar e proteção contra alteração indevida.
Interna	Procedimentos e documentos operacionais	Acesso a usuários autorizados.
Confidencial	Cadastro, contatos, contratos, dados financeiros e acadêmicos	Acesso por necessidade, MFA, logs e backup.
Restrita/sensível	Credenciais e dados pessoais sensíveis eventualmente tratados	Acesso estrito, proteção reforçada, retenção definida e rastreabilidade.

Gestores de setor devem validar a classificação, indicar proprietários dos dados e definir quem pode acessar, alterar, exportar e compartilhar cada conjunto.

4. Governança e responsabilidades

Papel	Responsabilidades
Direção	Aprovar o plano, definir prioridades e orçamento, nomear responsáveis e aceitar riscos residuais.
Coordenação de TI	Manter inventário, administrar controles, monitorar alertas, coordenar backups, atualizações e incidentes.
Encarregado/DPO ou responsável LGPD	Orientar sobre dados pessoais, apoiar solicitações de titulares e avaliação/comunicação de incidentes.
Gestores de setor	Autorizar acessos conforme função, revisar permissões e comunicar desligamentos/mudanças.
Professores/colaboradores	Proteger credenciais, bloquear telas, usar recursos adequadamente e reportar suspeitas.
Alunos	Cumprir regras de uso dos laboratórios, rede e aplicativo; não instalar programas nem contornar controles.
Fornecedores	Cumprir cláusulas de segurança, confidencialidade, suporte e notificação de incidentes.

Regras de gestão

- Toda conta deve ser individual e vinculada a uma pessoa ou serviço identificado. Contas compartilhadas devem ser eliminadas ou excepcionalmente controladas.
- A concessão de acesso exige solicitação, aprovação do gestor, prazo quando temporário e registro.
- Acesso administrativo deve ser separado da conta de uso diário e protegido por autenticação multifator (MFA).
- No desligamento, bloquear contas e revogar acessos no mesmo dia, conforme procedimento interno.

• Revisar permissões trimestralmente e sempre que houver mudança de função.

5. Política de controle de acesso

• Aplicar o menor privilégio: cada usuário recebe somente o acesso necessário à sua atividade.

• Exigir senhas únicas e robustas, recomendando comprimento mínimo de 12 caracteres; impedir compartilhamento e reutilização indevida.

• Ativar MFA em e-mail, VPN, painéis administrativos, hospedagem, nuvem, aplicativo e contas privilegiadas, quando disponível.

• Usar gerenciador institucional de senhas; não armazenar credenciais em planilhas abertas, mensagens ou papéis.

• Bloquear automaticamente sessões após inatividade e exigir bloqueio manual ao se afastar.

• Contas de alunos devem ser individuais, limitadas ao ambiente pedagógico e sem privilégios de instalação/administração.

• Contas de serviço devem ter finalidade documentada, segredo protegido, rotação e proprietário responsável.

Perfil	Recursos	Permissão recomendada
Aluno	Laboratórios, rede estudantil e portal	Acesso individual limitado; sem administração local.
Professor	Sistemas pedagógicos, arquivos da disciplina e e-mail	Acesso às próprias turmas e conteúdos autorizados.
Administrativo	Sistemas do setor	Acesso conforme função e aprovação do gestor.
TI	Infraestrutura e ferramentas de gestão	Acesso privilegiado nominal, MFA e logs.
Fornecedor	Serviço contratado	Acesso temporário, restrito, supervisionado e revogado ao término.

6. Segurança física e do data center

• Manter o data center em sala exclusiva, trancada e com acesso limitado à equipe autorizada.

• Registrar entrada e saída, inclusive de fornecedores, e acompanhar visitas técnicas.

• Instalar e testar nobreak/UPS para servidores e rede essenciais; avaliar gerador conforme criticidade e orçamento.

• Monitorar temperatura, umidade, energia, fumaça e risco de vazamento; manter extintores adequados e inspeções em dia.

• Organizar e identificar cabeamento, circuitos e equipamentos; manter documentação atualizada.

• Não armazenar materiais estranhos ao ambiente técnico.

• Manter cópias de segurança fora do data center; uma cópia deve ser offline ou imutável, quando viável.

• Descartar discos com apagamento seguro ou destruição certificada da mídia.

7. Segurança de rede, internet e Wi-Fi

• Implantar ou revisar firewall na borda, com regras documentadas, revisão periódica e administração protegida por MFA.

• Separar redes de administração, professores, alunos/laboratórios, servidores, visitantes e dispositivos de infraestrutura (VLANs ou equivalente).

• Impedir que a rede de alunos/visitantes alcance diretamente o data center, servidor de arquivos e painéis administrativos.

• Oferecer Wi-Fi de visitantes separado, sem acesso à rede interna.

• Desativar serviços e protocolos inseguros desnecessários; preferir conexões criptografadas.

• Proteger equipamentos de rede com senhas únicas, firmware atualizado e backup de configuração.

• Monitorar disponibilidade e uso de banda; manter plano de contingência e contato do provedor.

• Avaliar filtro DNS/web para reduzir acesso a domínios maliciosos e conteúdo inadequado no ambiente escolar.

8. Proteção de desktops, notebooks e laboratórios

Os três laboratórios somam aproximadamente 90 computadores. A padronização reduz falhas e facilita a recuperação. A mesma política deve alcançar equipamentos de professores e funcionários.

- Manter sistemas operacionais e aplicativos suportados e atualizados.
- Instalar proteção antimalware/EDR gerenciada, com atualização e alertas centralizados.
- Usuários comuns não devem possuir privilégio de administrador local.
- Aplicar imagem padrão nos laboratórios, com software autorizado e configuração segura; restaurar a imagem periodicamente.
- Restringir instalação de programas, extensões e uso de mídias USB desconhecidas.
- Limpar sessões e arquivos locais de alunos ao final de cada aula ou por política automatizada.
- Habilitar criptografia de disco nos dispositivos que armazenem dados institucionais.
- Manter inventário de licenças, aplicativos permitidos e responsáveis por atualização.
- Retirar de uso equipamentos sem suporte ou incapazes de receber correções de segurança.

9. Servidor de arquivos e armazenamento

- Organizar pastas por setor e finalidade, com permissões por grupos.
- Evitar pastas abertas para todos; revisar permissões e compartilhamentos externos trimestralmente.
- Registrar acesso, alteração e exclusão de arquivos críticos, quando a plataforma permitir.
- Ativar versionamento ou snapshots para recuperar exclusões e alterações indevidas.
- Criptografar dados em trânsito e, quando viável, em repouso.
- Definir prazos de retenção por categoria documental com orientação jurídica/administrativa.
- Proibir cópias de dados institucionais em nuvens pessoais e dispositivos não gerenciados.

10. Site institucional, hospedagem e aplicativo

O site hospedado por terceiro e o aplicativo devem ser tratados como ativos críticos, mesmo quando parte da operação é terceirizada.

- Manter domínio, hospedagem, contas de administração e publicação em nome da instituição, com pelo menos dois responsáveis autorizados.
- Ativar MFA no registrador de domínio, painel de hospedagem, repositório de código e lojas de aplicativos.
- Exigir HTTPS/TLS e monitorar validade/renovação do certificado.
- Manter CMS, plugins, bibliotecas, frameworks e dependências atualizados; remover componentes sem suporte.
- Fazer backup do site, banco de dados, arquivos e configurações antes de atualizações e em rotina definida.
- Separar ambiente de testes e produção; mudanças devem ser testadas e aprovadas.
- Proteger formulários e APIs com autenticação, autorização, limites de requisição e medidas contra abuso.
- Formalizar contrato: disponibilidade, backup, suporte, localização dos dados, subcontratados, incidentes e encerramento.
- Revisar dados coletados pelo aplicativo, integrações, tokens e contas de publicação; remover acessos antigos.

11. Backup, recuperação e continuidade

Adotar a estratégia 3-2-1: três cópias dos dados, em dois tipos de mídia/ambientes, com uma cópia fora do ambiente principal. Sempre que possível, manter uma cópia offline ou imutável para proteção contra ransomware.

Sistema/dado	Frequência inicial	Retenção inicial	Teste
Servidor de arquivos	Incremental diário + completo semanal	Diário 30 dias; semanal 8 semanas; mensal 12 meses, ajustar	Amostra mensal e restauração semestral

Sistema/dado	Frequência inicial	Retenção inicial	Teste
Servidores/configurações	Diário e antes de mudanças	30–90 dias conforme criticidade	Restauração semestral
Site e banco de dados	Diário; antes de atualizações	Mínimo 30 dias, conforme contrato	Trimestral em teste
Aplicativo	A cada mudança relevante + dados diários	Conforme criticidade e contrato	Trimestral
Configurações de rede	Após mudanças e revisão mensal	Histórico mínimo sugerido de 12 meses	Semestral

Metas de recuperação propostas

Serviço	RTO – tempo-alvo de retorno	RPO – perda máxima de dados desejada
Sistemas acadêmicos essenciais	Até 8 horas	Até 4 horas
Servidor de arquivos	Até 8 horas	Até 24 horas; reduzir para dados críticos
Internet/rede principal	Até 4 horas, com contingência	Preservar configurações
Site institucional	Até 24 horas	Até 24 horas
Aplicativo	Até 24 horas, conforme fornecedor	Até 24 horas

RTO é o tempo-alvo para restabelecer o serviço; RPO é a quantidade máxima de dados que se aceita perder, medida em tempo. São metas iniciais para validação pela direção e TI.

Procedimento mínimo de restauração

- Abrir registro do teste/incidente e identificar sistema, ponto de restauração e responsável.
- Restaurar em ambiente isolado, quando possível, para verificar integridade e ausência de malware.
- Validar arquivos, permissões, banco de dados e funcionamento com o gestor do sistema.
- Registrar duração, falhas, dados recuperados e ações corretivas.
- Não considerar um backup confiável sem teste periódico de restauração.

12. Monitoramento, logs e vulnerabilidades

- Centralizar logs de firewall, servidores, sistemas críticos, hospedagem e contas administrativas sempre que possível.
- Sincronizar relógios dos equipamentos com fonte de tempo confiável.
- Monitorar tentativas de login, privilégios elevados, alterações de configuração, falhas de backup, malware e indisponibilidade.
- Restringir acesso aos logs e protegê-los contra alteração; definir retenção compatível com necessidade e legislação.
- Executar varreduras de vulnerabilidades autorizadas, priorizando sistemas expostos à internet e ativos críticos.
- Corrigir vulnerabilidades críticas com prioridade e registrar justificativa quando não for possível.
- Realizar avaliação técnica independente periodicamente e após mudanças relevantes.

13. Proteção de dados pessoais e LGPD

A IE provavelmente trata dados pessoais de alunos, responsáveis, professores e colaboradores. Deve identificar quais dados coleta, finalidades, base legal, prazo de retenção e compartilhamentos. A LGPD exige medidas técnicas e administrativas aptas a proteger os dados pessoais.

- Manter inventário das operações: cadastro, matrícula, notas, frequência, contatos, cobrança, RH, câmeras e aplicativo, conforme aplicável.
- Coletar apenas dados necessários e informar titulares sobre finalidades e canais de contato.
- Definir processo para atender solicitações de titulares, respeitando prazos e exceções legais.
- Formalizar contratos com operadores/fornecedores, incluindo confidencialidade, segurança, subcontratação, incidentes e descarte.

- Controlar compartilhamento de planilhas e documentos; evitar envio de dados por canais não autorizados.
- Estabelecer procedimento para incidentes com dados pessoais e avaliar comunicação à ANPD e aos titulares, conforme regulamentação aplicável.
- Aplicar proteção reforçada a dados de crianças e adolescentes, observando o melhor interesse e exigências legais.

A direção deve designar encarregado ou canal responsável por privacidade e buscar orientação jurídica especializada para decisões legais específicas.

14. Conscientização e uso aceitável

- Realizar treinamento inicial e reciclagem anual sobre phishing, senhas, MFA, dados pessoais e comunicação de incidentes.
- Não abrir links/anexos suspeitos nem fornecer senha ou código MFA.
- Não instalar programas, extensões ou aplicativos sem autorização.
- Não compartilhar contas, senhas, listas de alunos ou documentos internos em serviços pessoais.
- Usar apenas redes e dispositivos autorizados para acessar informações institucionais.
- Comunicar perda/roubo de notebook, suspeita de invasão, arquivo criptografado ou envio incorreto de dados.
- Nos laboratórios, não alterar configurações, conectar dispositivos desconhecidos ou tentar contornar controles.
- Campanhas de phishing simulado devem ser educativas, sem exposição ou punição indevida.

15. Gestão e resposta a incidentes

Incidente é qualquer evento que comprometa ou ameace confidencialidade, integridade ou disponibilidade: ransomware, malware, conta invadida, vazamento, perda de equipamento, indisponibilidade ou alteração indevida.

Etapa	Ação
1. Identificação	Usuário comunica à TI por canal definido; registrar data, hora, sistema, sintomas e evidências.
2. Classificação	TI avalia impacto, alcance, dados afetados, criticidade e necessidade de envolver direção/encarregado.
3. Contenção	Isolar equipamento/rede ou conta; bloquear credenciais e sessões; preservar evidências. Não formatar sem orientação.
4. Erradicação	Remover malware, corrigir vulnerabilidade, revogar tokens, redefinir credenciais e fechar o vetor de entrada.
5. Recuperação	Restaurar de backup confiável, validar integridade e monitorar retorno seguro.
6. Comunicação	Direção, áreas afetadas, fornecedores e encarregado avaliam comunicações internas, contratuais e legais.
7. Lições aprendidas	Documentar causa raiz, impacto, tempo de resposta, falhas de controle e ações preventivas.

Níveis de severidade

Nível	Exemplo	Tratamento
Crítico	Ransomware no servidor, vazamento amplo, data center indisponível	Acionar direção e TI imediatamente; priorizar contenção e continuidade.
Alto	Conta administrativa invadida, malware em vários computadores, sistema acadêmico fora do ar	Resposta prioritária no mesmo turno; avaliar escopo.
Moderado	Um computador infectado ou acesso indevido limitado	Conter, corrigir e registrar.
Baixo	Tentativa bloqueada sem evidência de comprometimento	Registrar tendência e ajustar prevenção.

Regra: usuários não devem investigar por conta própria, apagar evidências ou negociar com criminosos. A TI deve preservar registros e escalar incidentes relevantes.

16. Gestão de fornecedores

- Manter lista de fornecedores, serviço prestado, contato de emergência, sistemas acessados e dados tratados.
- Avaliar controles de segurança antes da contratação e periodicamente.

- Exigir cláusulas de confidencialidade, proteção de dados, controle de acesso, notificação de incidentes, backup, continuidade e descarte.
- Conceder acesso remoto somente quando necessário, com MFA, janela autorizada, registro e supervisão.
- Revisar contas e chaves de fornecedores após mudanças contratuais.
- Planejar encerramento: exportar dados, transferir domínio/código, revogar acessos e confirmar eliminação de cópias.

17. Plano de implantação

Implantar gradualmente, priorizando riscos que podem causar perda de dados ou paralisação.

Prazo	Ações prioritárias	Entregáveis
0–30 dias	Nomear responsáveis; inventariar ativos/contas críticas; revisar acessos; verificar backups; ativar MFA crítico; definir canal de incidentes.	Inventário inicial; lista de contas privilegiadas; relatório de backup.
31–60 dias	Revisar firewall/Wi-Fi; separar rede de alunos e servidores; padronizar laboratórios; atualizar sistemas; formalizar regras.	Diagrama de rede; política de acesso; padrão dos laboratórios.
61–90 dias	Implantar rotina 3-2-1; testar restauração; revisar permissões do servidor; avaliar contratos do site/app; treinar equipe.	Relatório de restauração; matriz de permissões; avaliação de fornecedores.
3–6 meses	Centralizar logs; avaliar EDR; executar avaliação de vulnerabilidades; simular incidente e continuidade.	Painel de indicadores; relatório técnico; simulado documentado.
Contínuo	Revisar acessos trimestralmente; testar backups; treinar anualmente; revisar plano após mudanças.	Atas de revisão; evidências de testes; plano atualizado.

18. Indicadores de segurança

Indicador	Meta inicial	Periodicidade
Ativos inventariados	≥ 95% dos ativos conhecidos	Mensal até concluir; depois trimestral
Contas críticas com MFA	100% das contas administrativas compatíveis	Mensal
Endpoints com proteção ativa	≥ 95% dos equipamentos suportados	Mensal
Atualizações críticas	≥ 95% no prazo definido pela TI	Mensal
Execuções de backup sem falha	≥ 98%	Semanal/mensal
Testes de restauração	100% dos testes planejados	Trimestral/semestral
Revisão de acessos	100% dos sistemas críticos	Trimestral
Treinamento	≥ 90% dos colaboradores	Anual
Incidentes registrados	100% dos reportados com responsável	Mensal

19. Riscos prioritários e tratamento

Risco	Probabilidade/impacto inicial	Tratamento prioritário
Ransomware no servidor de arquivos	Alta / Muito alto	Backups isolados, MFA, EDR, segmentação e testes.
Vazamento de dados pessoais	Média / Muito alto	Menor privilégio, criptografia, logs, treinamento e processo LGPD.
Invasão de site/aplicativo	Média / Alto	MFA, atualização, backup, revisão técnica e gestão do fornecedor.
Acesso indevido pela rede dos laboratórios	Alta / Alto	Segmentação, contas limitadas, imagem padrão e bloqueio de privilégios.
Falha elétrica/física no data center	Média / Alto	UPS, sensores, controle físico, cópia externa e recuperação.
Perda/roubo de notebook	Média / Alto	Criptografia, bloqueio, inventário e revogação de sessões.
Falha do provedor/hospedagem	Média / Médio/alto	SLA, contatos, backups independentes e contingência.

A classificação é preliminar e qualitativa. Deve ser validada com histórico, arquitetura, impacto real e criticidade dos serviços.

20. Documentos e evidências a manter

- Inventário de hardware, software, sistemas, contas e fornecedores.
- Diagrama atualizado da rede e do data center.
- Matriz de acesso e aprovações de concessão/revogação.
- Política de backup, relatórios de execução e evidências de restauração.
- Registros de atualização, antimalware/EDR, vulnerabilidades e correções.
- Contratos de hospedagem, aplicativo, internet e suporte.
- Registro de incidentes, decisões, comunicações e lições aprendidas.
- Registros de treinamento, campanhas e revisões do plano.
- Inventário de tratamento de dados pessoais e avisos/procedimentos LGPD.

21. Checklist de verificação inicial

Marcar Sim, Não ou Não se aplica e registrar evidência e responsável.

Verificação	Status	Evidência/responsável
Existe inventário atualizado de servidores, computadores e rede?	■ Sim ■ Não ■ N/A	
Acesso físico ao data center é restrito e registrado?	■ Sim ■ Não ■ N/A	
Há backup do servidor de arquivos e cópia externa?	■ Sim ■ Não ■ N/A	
Foi testada restauração nos últimos seis meses?	■ Sim ■ Não ■ N/A	
Contas administrativas usam MFA?	■ Sim ■ Não ■ N/A	
Rede de alunos/visitantes é separada dos servidores?	■ Sim ■ Não ■ N/A	
Laboratórios têm imagem padrão e proteção ativa?	■ Sim ■ Não ■ N/A	
Sistemas e equipamentos recebem atualizações?	■ Sim ■ Não ■ N/A	
Domínio, hospedagem e app estão sob controle institucional?	■ Sim ■ Não ■ N/A	
Contratos preveem segurança e notificação de incidentes?	■ Sim ■ Não ■ N/A	
Existe canal e procedimento para reportar incidentes?	■ Sim ■ Não ■ N/A	
Colaboradores receberam treinamento?	■ Sim ■ Não ■ N/A	
Há processo para solicitações relacionadas à LGPD?	■ Sim ■ Não ■ N/A	

22. Aprovação e revisão

Este plano entra em vigor após aprovação formal da direção. A Coordenação de TI deve manter a versão vigente, comunicar mudanças e revisar o documento ao menos anualmente, após incidentes relevantes, mudanças na infraestrutura, contratação de novos serviços ou alterações legais.

Aprovação	Nome/assinatura	Data
Direção da instituição		
Responsável pela TI		
Encarregado/responsável por privacidade		

Referências orientativas

• Lei nº 13.709/2018 – Lei Geral de Proteção de Dados Pessoais (LGPD).
• ISO/IEC 27001 e ISO/IEC 27002 – referências para gestão e controles de segurança da informação; este documento não declara certificação.
• NIST Cybersecurity Framework 2.0 – Governar, Identificar, Proteger, Detectar, Responder e Recuperar.
• Boas práticas de backup 3-2-1, gestão de vulnerabilidades, controle de acesso e resposta a incidentes.

Nota final: a adoção deste plano não substitui auditoria técnica, avaliação jurídica ou análise detalhada dos sistemas e contratos. Os controles devem ser dimensionados e validados pelos profissionais responsáveis.